

Recomendación

UIT-T X.1353 (09/2024)

SERIE X: Redes de datos, comunicaciones de sistemas abiertos y seguridad

Aplicaciones y servicios seguros (II) – Seguridad de la Internet de las cosas (IoT)

Metodología de seguridad basada en cadenas de bloques para instalaciones sin intervención de IoT masiva

RECOMENDACIONES UIT-T DE LA SERIE X

Redes de datos, comunicaciones de sistemas abiertos y seguridad

REDES PÚBLICAS DE DATOS	X.1-X.199
INTERCONEXIÓN DE SISTEMAS ABIERTOS	X.200-X.299
INTERFUNCIONAMIENTO ENTRE REDES	X.300-X.399
SISTEMAS DE TRATAMIENTO DE MENSAJES	X.400-X.499
DIRECTORIO	X.500-X.599
GESTIÓN DE REDES DE INTERCONEXIÓN DE SISTEMAS ABIERTOS Y ASPECTOS DE SISTEMAS	X.600-X.699
GESTIÓN DE INTERCONEXIÓN DE SISTEMAS ABIERTOS	X.700-X.799
SEGURIDAD	X.800-X.849
APLICACIONES DE INTERCONEXIÓN DE SISTEMAS ABIERTOS	X.850-X.899
PROCESAMIENTO DISTRIBUIDO ABIERTO	X.900-X.999
SEGURIDAD DE LA INFORMACIÓN Y DE LAS REDES	X.1000-X.1099
APLICACIONES Y SERVICIOS CON SEGURIDAD (I)	X.1100-X.1199
SEGURIDAD EN EL CIBERESPACIO	X.1200-X.1299
APLICACIONES Y SERVICIOS SEGUROS (II)	X.1300-X.1499
Comunicaciones de emergencia	X.1300-X.1309
Seguridad en las redes de sensores ubicuos	X.1310-X.1319
Seguridad en sistemas eléctricos inteligentes	X.1330-X.1339
Correo certificado	X.1340-X.1349
Seguridad de la Internet de las cosas (IoT)	X.1350-X.1369
Seguridad en los sistemas de transporte inteligente (ITS)	X.1370-X.1399
Seguridad de tecnología de libro mayor distribuido	X.1400-X.1429
Seguridad de las aplicaciones (2)	X.1450-X.1459
Seguridad en la web (2)	X.1470-X.1489
INTERCAMBIO DE INFORMACIÓN DE CIBERSEGURIDAD	X.1500-X.1599
SEGURIDAD DE LA COMPUTACIÓN EN NUBE	X.1600-X.1699
COMUNICACIÓN CUÁNTICA	X.1700-X.1729
SEGURIDAD DE LOS DATOS	X.1750-X.1799
SEGURIDAD EN LAS REDES IMT-2020	X.1800-X.1819
SEGURIDAD DEL METAVERSO Y DE LOS GEMELOS DIGITALES	X.2000-X.2199
SEGURIDAD DE LA CADENA DE SUMINISTRO DE SOFTWARE	X.2150-X.2199
SEGURIDAD DE LA INTELIGENCIA ARTIFICIAL / APRENDIZAJE AUTOMÁTICO	X.2200-X.2249

Para más información, véase la Lista de Recomendaciones del UIT-T.

Recomendación UIT-T X.1353

Metodología de seguridad basada en cadenas de bloques para instalaciones sin intervención de IoT masiva

Resumen

La Internet de las cosas masiva (mIoT) es una importante aplicación de las futuras redes de comunicaciones. A la vista de los numerosos casos de uso previstos de la mIoT, resulta difícil para los fabricantes preconfigurar sus dispositivos IoT prefabricados con información específica del operador móvil o el servicio (por ejemplo, identificadores y claves), ya que los fabricantes pueden desconocer dónde y cómo se desplegarán y se activarán finalmente sus dispositivos. El enfoque actual se basa en una configuración manual realizada por los clientes, que es aceptable para aplicaciones de IoT a pequeña escala. Sin embargo, en el caso de dispositivos mIoT, dicho enfoque es inaceptable debido a que la configuración manual lleva mucho tiempo, es poco rentable y engorrosa. Por lo tanto, la mIoT requiere la provisión automática de credenciales sin la participación del usuario, conocida como "sin intervención".

La Recomendación UIT-T X.1353 proporciona una metodología de seguridad para el diseño de sistemas descentralizados de gestión de credenciales que permitan futuras instalaciones sin intervención de mIoT basadas en cadenas de bloques. Se trata en este caso de un enfoque viable y prometedor para lograr el despliegue sin intervención de la futura mIoT. De esta forma, los dispositivos IoT podrán obtener credenciales automáticamente de su operador de red móvil (MNO) y su proveedor de servicios (PS) y conectarse automáticamente a la red y al servicio. Esto facilitará en gran medida la futura instalación de dispositivos mIoT en ámbitos verticales. La presente Recomendación abarca la arquitectura de seguridad, las consideraciones relativas a la seguridad y los procedimientos de seguridad conexos (véanse las acreditaciones de dispositivos, la autenticación y la provisión de credenciales), que son esenciales para crear una plataforma de instalación sin intervención para la mIoT.

Historia*

Edición	Recomendación	Aprobación	Comisión de Estudio	ID único
1.0	UIT-T X.1353	06-09-2024	17	11.1002/1000/15105

Palabras clave

Provisión de credenciales, IoT masiva, instalación sin intervención.

* Para acceder a la Recomendación, sírvase digitar el URL <https://handle.itu.int/> en el campo de dirección del navegador, seguido por el identificador único de la Recomendación.

PREFACIO

La Unión Internacional de Telecomunicaciones (UIT) es el organismo especializado de las Naciones Unidas en el campo de las telecomunicaciones y de las tecnologías de la información y la comunicación. El Sector de Normalización de las Telecomunicaciones de la UIT (UIT-T) es un órgano permanente de la UIT. Este órgano estudia los aspectos técnicos, de explotación y tarifarios y publica Recomendaciones sobre los mismos, con miras a la normalización de las telecomunicaciones en el plano mundial.

La Asamblea Mundial de Normalización de las Telecomunicaciones (AMNT), que se celebra cada cuatro años, establece los temas que han de estudiar las Comisiones de Estudio del UIT-T, que a su vez producen Recomendaciones sobre dichos temas.

La aprobación de Recomendaciones por los Miembros del UIT-T es el objeto del procedimiento establecido en la Resolución 1 de la AMNT.

En ciertos sectores de la tecnología de la información que corresponden a la esfera de competencia del UIT-T, se preparan las normas necesarias en colaboración con la ISO y la CEI.

NOTA

En esta Recomendación, la expresión "Administración" se utiliza para designar, en forma abreviada, tanto una administración de telecomunicaciones como una empresa de explotación reconocida de telecomunicaciones.

La observancia de esta Recomendación es voluntaria. Ahora bien, la Recomendación puede contener ciertas disposiciones obligatorias (para asegurar, por ejemplo, la aplicabilidad o la interoperabilidad), por lo que la observancia se consigue con el cumplimiento exacto y puntual de todas las disposiciones obligatorias. La obligatoriedad de un elemento preceptivo o requisito se expresa mediante las frases "tener que, haber de, hay que + infinitivo" o el verbo principal en tiempo futuro simple de mandato, en modo afirmativo o negativo. El hecho de que se utilice esta formulación no entraña que la observancia se imponga a ninguna de las partes.

PROPIEDAD INTELECTUAL

La UIT señala a la atención la posibilidad de que la utilización o aplicación de la presente Recomendación suponga el empleo de un derecho de propiedad intelectual reivindicado. La UIT no se pronuncia en lo que respecta a la existencia, validez o aplicabilidad de los derechos de propiedad intelectual reclamados, ya sea por los miembros de la UIT o por terceros ajenos al proceso de elaboración de Recomendaciones.

En la fecha de aprobación de la presente Recomendación, la UIT no ha recibido notificación de propiedad intelectual, protegida por patentes/derechos de autor de *software*, que puede ser necesaria para aplicar esta Recomendación. Sin embargo, debe señalarse a los usuarios que puede que esta información no se encuentre totalmente actualizada al respecto, por lo que se les insta encarecidamente a consultar las correspondientes bases de datos del UIT-T disponibles en el sitio web del UIT-T en <http://www.itu.int/ITU-T/ipr/>.

© UIT 2025

Reservados todos los derechos. Ninguna parte de esta publicación puede reproducirse por ningún procedimiento sin previa autorización escrita por parte de la UIT.

ÍNDICE

	Página
1 Alcance	1
2 Referencias	1
3 Definiciones.....	1
3.1 Términos definidos en otros documentos.....	1
3.2 Términos definidos en esta Recomendación	2
4 Siglas y acrónimos.....	3
5 Convenios	3
6 Motivos por los que se necesita una plataforma de instalación sin intervención para la IoT masiva	4
7 Arquitectura de la plataforma de instalación sin intervención	4
7.1 Componentes principales.....	4
7.2 Requisitos de seguridad.....	10
8 Controles de seguridad para una instalación sin intervención basada en cadenas de bloques.....	11
8.1 Diseño general del protocolo.....	11
8.2 Acreditación del dispositivo	14
8.3 Autenticación.....	14
8.4 Provisión de credenciales	15
9 Protección de los datos de identificación.....	16
9.1 Datos de identificación	16
9.2 Requisitos de protección de los datos de identificación.....	16
Apéndice I – Contrato inteligente para la gestión de la identidad de los dispositivos.....	17
Apéndice II – Procedimientos de gestión de dispositivos.....	18
II.1 Introducción.....	18
II.2 Creación del perfil de identidad	18
II.3 Recuperación del perfil de identidad	20
Bibliografía	24

Recomendación UIT-T X.1353

Metodología de seguridad basada en cadenas de bloques para instalaciones sin intervención de IoT masiva

1 Alcance

La presente Recomendación se centra en la metodología de seguridad y los diseños de seguridad conexos para instalaciones sin intervención de la futura IoT masiva (mIoT) basados en la tecnología de cadenas de bloques. En concreto, esta Recomendación abarca la arquitectura de seguridad, las consideraciones relativas a la seguridad y los procedimientos de seguridad conexos (como las acreditaciones de dispositivos, la autenticación y la provisión de credenciales), que son necesarios para construir una plataforma de instalación sin intervención para la IoT masiva.

2 Referencias

Las siguientes Recomendaciones del UIT-T y otras referencias contienen disposiciones que, mediante su referencia en este texto, constituyen disposiciones de la presente Recomendación. Al efectuar esta publicación, estaban en vigor las ediciones indicadas. Todas las Recomendaciones y otras referencias son objeto de revisiones, por lo que se alienta a los usuarios de esta Recomendación a que investiguen la posibilidad de aplicar las ediciones más recientes de las Recomendaciones y otras referencias citadas a continuación. Se publica periódicamente una lista de las Recomendaciones UIT-T vigentes. La referencia a un documento en el marco de la presente Recomendación no le confiere carácter de Recomendación.

Ninguna.

3 Definiciones

3.1 Términos definidos en otros documentos

En esta Recomendación se utilizan los siguientes términos definidos en otros documentos:

3.1.1 control de acceso [b-ISO/CEI 10027]: capacidad de restringir la utilización de los servicios de acceso a los datos a usuarios que han sido previamente autorizados.

3.1.2 dirección [b-UIT-T X.1400]: identificador de entidad o entidades que realizan transacciones u otras actividades en una cadena de bloques o una red de libro mayor distribuido.

3.1.3 autenticación [b-UIT-T X.1254]: provisión de garantía de la identidad declarada por una entidad.

3.1.4 bloque [b-UIT-T X.1400]: unidad de datos individual de una cadena de bloques compuesta por un conjunto de transacciones y una cabecera de bloque.

3.1.5 cadena de bloques [b-UIT-T X.1400]: tipo de libro mayor distribuido que se compone de datos registrados digitalmente dispuestos en forma de cadena de bloques que crece sucesivamente, estando todos los bloques criptográficamente vinculados y reforzados contra la manipulación y la revisión.

3.1.6 dispositivo [b-UIT-T Y.4000]: en el contexto de Internet de las cosas, se trata de un equipo con las capacidades obligatorias de comunicación y las capacidades opcionales de detección, accionamiento, adquisición, almacenamiento y procesamiento de datos.

3.1.7 gestión de identidad [b-UIT-T X.1250]: conjunto de funciones y capacidades (por ejemplo, administración, gestión y mantenimiento, descubrimiento, intercambios de comunicación, correlación y vinculación, cumplimiento de una política, autenticación y asertos) que se utilizan para:

- garantizar la información de identidad (por ejemplo, identificadores, credenciales, atributos);
- garantizar la identidad de una entidad (por ejemplo, usuarios/abonados, grupos, dispositivos de usuario, organizaciones, proveedores de red y servicios, elementos y objetos de red, y objetos virtuales); y
- apoyar aplicaciones de negocios y de seguridad.

3.1.8 Internet de las cosas (IoT) [b-UIT-T Y.4000]: infraestructura mundial para la sociedad de la información que propicia la prestación de servicios avanzados mediante la interconexión de objetos (físicos y virtuales) gracias a la interoperabilidad de tecnologías de la información y la comunicación presentes y futuras.

NOTA 1 – Gracias a la identificación, la adquisición y el procesamiento de datos y a las capacidades de comunicación, la IoT hace pleno uso de los objetos para ofrecer servicios a todo tipo de aplicaciones, garantizando a su vez el cumplimiento íntegro de los requisitos de seguridad y privacidad.

NOTA 2 – Desde una perspectiva más amplia, IoT puede considerarse una visión con repercusiones tecnológicas y sociales.

3.1.9 gestión de claves [b-UIT-T X.800]: generación, almacenamiento, distribución, supresión, archivo y aplicación de claves de acuerdo con una política de seguridad.

3.1.10 clave privada [b-UIT-T X.509]: (en un criptosistema de claves públicas) una de las claves del par de claves de una entidad que solo es conocida por esa entidad.

3.1.11 clave pública [b-UIT-T X.509]: clave del par de claves de una entidad que es de dominio público.

3.1.12 módulo de seguridad (SecM) [b-UIT-T X.1365]: elemento de *software* o de *hardware*, o la combinación de ambos, que implementa de manera segura mecanismos criptográficos y ofrece servicios de seguridad.

3.1.13 contrato inteligente [b-UIT-T L.1317]: programa escrito en el sistema de libro mayor distribuido que codifica las reglas para tipos específicos de transacciones del sistema de libro mayor distribuido de una manera que puede ser validada, y activada por condiciones específicas.

3.1.14 transacción [b-UIT-T L.1317]: conjunto de intercambios de información entre nodos. Una transacción se identifica unívocamente mediante un identificador de transacción.

3.2 Términos definidos en esta Recomendación

En esta Recomendación se definen los términos siguientes:

3.2.1 datos de identificación: todo dato que se pueda utilizar para reconocer o identificar un dispositivo o su usuario, que pueda estar directa o indirectamente vinculado al dispositivo a que se refiere ese dato.

3.2.2 IoT masiva: un gran número (generalmente, entre miles y millones) de dispositivos de la Internet de las cosas (IoT) que conectan redes de telecomunicaciones.

3.2.3 instalación sin intervención: proceso de instalación que se ejecuta de forma automática y sin intervención del usuario.

3.2.4 provisión de credenciales sin intervención: proceso de provisión de credenciales que se ejecuta de forma automática y sin intervención del usuario.

4 Abreviaturas y acrónimos

En la presente Recomendación se utilizan las siguientes abreviaturas y acrónimos:

ABE	Encriptación basada en atributos (<i>attribute-based encryption</i>)
ABI	Interfaz binario de la aplicación (<i>application binary interface</i>)
AuC	Centro de autenticación (<i>authentication centre</i>)
ECIES	Esquema de encriptación integrado de curva elíptica (<i>elliptic curve integrated encryption scheme</i>)
IDeVID	Identificador inicial de dispositivo (<i>initial device identifier</i>)
IdP	Proveedor de identidad (<i>identity provider</i>)
IMEI	Identidad internacional de equipo móvil (<i>international mobile equipment identity</i>)
IMSI	Identidad internacional de abonado móvil (<i>international mobile subscriber identity</i>)
IoT	Internet de las cosas (<i>Internet of things</i>)
IPFS	Sistema de archivo interplanetario (<i>inter-planet file system</i>)
KMS	Sistema de gestión de claves (<i>key management system</i>)
MNO	Operador de red móvil (<i>mobile network operator</i>)
PS	Proveedor de servicios
SecM	Módulo seguro (<i>secure module</i>)
SIM	Módulo de identificación de abonado (<i>subscriber identification module</i>)
TLS	Seguridad de la capa de transporte (<i>transport layer security</i>)
URI	Identificador uniforme de recursos (<i>uniform resource identifier</i>)
URL	Localizador uniforme de recursos (<i>uniform resource locator</i>)

5 Convenios

En la presente Recomendación se utilizan los siguientes convenios:

La utilización de forma verbal de "**futuro**" indica un requisito que debe cumplirse estrictamente, sin permitirse desviación alguna si se va a invocar la conformidad con la presente Recomendación.

La expresión "**debería**" indica un requisito recomendado pero que no es absolutamente obligatorio.

En el cuerpo de la presente Recomendación, ocasionalmente puede aparecer el verbo auxiliar "**puede**", en cuyo caso deben interpretarse como "**es capaz de**".

Cuando estas expresiones o términos aparecen en apéndices o en partes incluidas explícitamente a título informativo no deben interpretarse en su sentido normativo.

6 Motivos por los que se necesita una plataforma de instalación sin intervención para la IoT masiva

La Internet de las cosas (IoT) abarca una amplia gama de casos de uso, como el hogar inteligente, los dispositivos ponibles inteligentes, la agricultura inteligente, la fabricación inteligente, los servicios públicos inteligentes y la ciudad inteligente, que ofrecen nuevas oportunidades de negocio y nuevas consideraciones operativas para las futuras redes de telecomunicaciones. Los diversos casos de uso previstos de la IoT permiten vislumbrar una amplia diversidad de tipos de dispositivos IoT y de las características y las demandas de los diferentes dispositivos IoT. Por lo tanto, es difícil para los fabricantes preconfigurar sus dispositivos IoT con información específica del operador móvil y del servicio (por ejemplo, los identificadores y las claves), ya que los fabricantes pueden desconocer dónde se desplegarán sus dispositivos y para qué servicio se activarán. El enfoque actual deja estas cuestiones en manos de los consumidores. Los consumidores tienen que instalar en sus dispositivos IoT las tarjetas del módulo de identificación del abonado (SIM) que compran a su operador de red móvil (MNO) para su conexión a la red. También tienen que configurar manualmente en sus dispositivos IoT las credenciales que obtienen de su proveedor de servicios para poder utilizar el servicio. Esto es aceptable en los casos de aplicación de la IoT en que el número de dispositivos es reducido. Sin embargo, cuando el número de dispositivos IoT es masivo, el procedimiento es inaceptable debido a que la configuración manual requiere mucho tiempo, no resulta rentable y es engorrosa. Por lo tanto, la instalación masiva de IoT precisa de la provisión automática de credenciales sin la participación del usuario, lo que se conoce como tecnología "sin intervención".

Sin embargo, la provisión segura de una credencial a un dispositivo no contactado previamente es imposible sin ayuda externa. Cuando hay una tercera parte externa, pueden surgir numerosos problemas relacionados con la seguridad. En primer lugar, un tercero puede lanzar un ataque de intermediario para obtener la información de identificación del dispositivo. En segundo lugar, puede interceptar las credenciales y revenderlas o reutilizarlas. En tercer lugar, con un tercero centralizado se corre el riesgo de crear un punto de fallo único, lo que puede provocar la interrupción del servicio. Por lo tanto, para hacer frente a estos problemas, hay que diseñar una plataforma de instalación sin intervención, que otorgue un papel central a la seguridad desde la fase de diseño. La presente Recomendación proporciona una metodología de seguridad basada en cadenas de bloques que facilita el diseño seguro de futuras instalaciones masivas de IoT sin intervención, que constituye uno de los muchos enfoques que pueden aplicarse a efectos del despliegue sin intervención de la IoT masiva.

7 Arquitectura de la plataforma de instalación sin intervención

7.1 Componentes principales

Como se muestra en la Figura 1, una plataforma de instalación sin intervención precisa de la participación del fabricante del dispositivo, el mayorista, el minorista, el operador de red móvil y el proveedor de servicios. Los dispositivos son producidos por el fabricante y posteriormente distribuidos a los mayoristas y minoristas, que los venden a los usuarios. El MNO proporciona al usuario el acceso a la red y el proveedor de servicios proporciona al usuario el acceso al servicio. En las cláusulas 7.1.1 a 7.1.5 se describe detalladamente cada componente de la plataforma de instalación sin intervención.

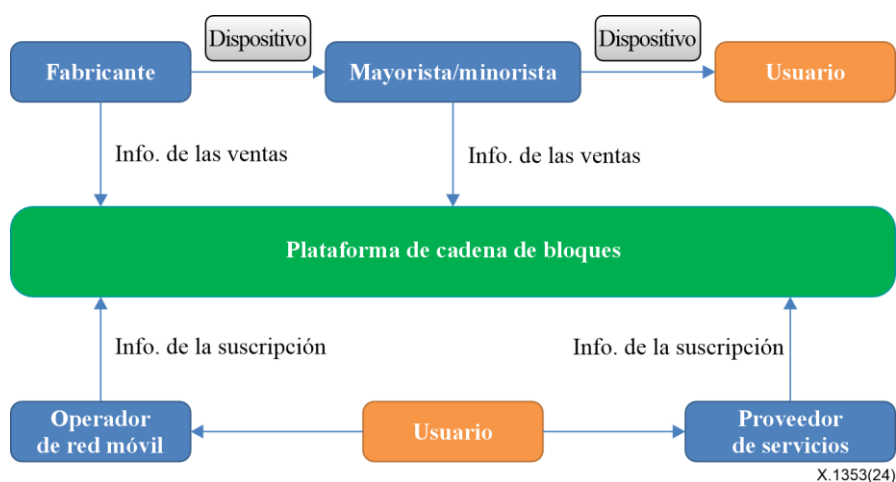


Figura 1 – Arquitectura de alto nivel de la plataforma de instalación sin intervención

7.1.1 Fabricante

El fabricante precisa dar una credencial inicial al dispositivo que ha fabricado. Esto se debe a que el dispositivo necesita la credencial inicial para su acreditación ante la plataforma de instalación sin intervención. Por lo tanto, esta credencial debe incorporarse durante el proceso de fabricación.

La credencial inicial debe incluir la dirección de acceso de la plataforma de cadena de bloques sin intervención (por ejemplo, un localizador uniforme de recursos (URL)) y el certificado raíz de la plataforma de cadena de bloques.

Además, el fabricante debe tener acceso a la plataforma de cadena de bloques. El fabricante debe cargar la información sobre la propiedad del dispositivo (la información que relaciona el dispositivo y sus propietarios, por ejemplo, mayoristas, minoristas o clientes) de forma protegida en la cadena de bloques con el fin de permitir una instalación sin intervención.

7.1.2 Mayorista y minorista

Un mayorista es un distribuidor que vende productos a minoristas. Un mayorista compra los aparatos directamente a un fabricante en grandes cantidades y luego los vende al por mayor a los minoristas. Por lo general, el mayorista no vende los aparatos directamente a los usuarios.

Un minorista vende los dispositivos directamente a los usuarios a través de diversos canales de distribución. Los minoristas son la parte de la cadena de suministro que se relaciona directamente con el consumidor. Existen diferentes tipos, estilos y tamaños.

Los mayoristas y los minoristas se encargan de distribuir los dispositivos de un fabricante a los usuarios. Para facilitar una instalación sin intervención, el mayorista debe cargar en la cadena de bloques la información de las ventas (la información de la correspondencia entre dispositivos y minoristas) de forma protegida, y el minorista debe cargar en la cadena de bloques la información de sus ventas (la información de la correspondencia entre dispositivos y usuarios) de forma protegida.

En este contexto, las funciones de mayorista y minorista son opcionales, ya que el fabricante puede vender los dispositivos directamente a los clientes.

7.1.3 Operador de red móvil

Un operador de red móvil (MNO) proporciona acceso a la red celular a los dispositivos IoT. En particular, un MNO proporciona servicios celulares en un país o región específicos, que se puede solapar con los de otros operadores de telefonía móvil. Un MNO cobra una suscripción por el acceso a sus servicios, normalmente en forma de un contrato que incluye servicios celulares específicos. Un MNO proporciona una credencial de acceso a todo usuario que firma un contrato de suscripción con

él. Una vez obtenida la credencial, el dispositivo del usuario puede ser autenticado y tener acceso a la red del MNO.

Para permitir instalaciones sin intervención, el MNO necesita cargar la información de suscripción (la información vinculante entre el MNO y el usuario) en la plataforma basada en cadena de bloques de forma protegida.

7.1.4 Proveedor de servicios

Un proveedor de servicios (PS) proporciona conectividad de servicios para dispositivos IoT. Un PS cobra una suscripción por el acceso a su plataforma de servicios, normalmente en forma de contrato que incluye servicios específicos. Un PS proporciona credenciales de acceso a los usuarios que firman contratos de suscripción con ellos. Con dicha credencial, el dispositivo del usuario puede ser autenticado y tener acceso a la plataforma de servicios del PS.

Para permitir las instalaciones sin intervención, el PS necesita cargar en la cadena de bloques la información de la suscripción (la información vinculante entre el PS y el usuario) de forma protegida.

7.1.5 Plataforma de cadena de bloques

El componente principal de la plataforma de instalación sin intervención es la plataforma de cadena de bloques. La cadena de bloques [b-UIT-T X.1411] es una tecnología prometedora y útil para construir sistemas descentralizados de gestión de la identidad para identificadores y datos de identidades (como atributos de identidad e información relacionada con la autenticación) [b-UIT-T Y.3081], debido a su inmutabilidad y enfoque basado en un consenso descentralizado. En la cadena de bloques, las transacciones o los datos se almacenan en nodos pares consensuados, y quedan protegidos por una cadena de funciones hash. Las modificaciones del registro histórico o de los valores hash de los bloques pueden detectarse comprobando la corrección del hash de bloques registrados en otro nodo. Esto evita que los atacantes puedan manipular los datos de las transacciones incorporadas en una cadena.

Las cadenas de bloques pueden clasificarse en tres tipos: públicas, de consorcio y privadas. Una cadena de bloques pública está diseñada para permitir y registrar transacciones en una red pública, es decir, que cualquier nodo puede unirse o abandonar libremente sin autorización la red de cadena de bloques. La cadena de bloques de consorcio es una cadena de bloques basada en permisos, que solo está abierta a miembros autorizados. Los nodos de una red de cadena de bloques de consorcio gozan de una gran confianza mutua. En consecuencia, las cadenas de consorcio pueden adoptar algoritmos sencillos de consenso para mejorar la eficacia del sistema. Las cadenas de bloques privadas son cadenas de bloques basadas en permisos controlados por una entidad. En los escenarios de instalación sin intervención, varias partes interesadas, incluidos los fabricantes, los operadores de redes móviles, los proveedores de servicios y los usuarios finales, participan en el ecosistema. Por lo tanto, para la operativa deseada pueden adoptarse cadenas de bloques públicas o cadenas de bloques de consorcio. Las cadenas de bloques de consorcio presentan ciertas ventajas en términos de eficiencia, escalabilidad y privacidad. Este tipo de cadenas cede el control a los miembros, siendo los miembros del consorcio los únicos facultados para ver las transacciones, característica que las diferencia de las cadenas de bloques públicas. En consecuencia, los datos gozan de una privacidad adecuada en las cadenas de bloques de consorcio.

Como se muestra en la Figura 1, las cadenas de bloques de consorcio pueden ser construidas y mantenidas conjuntamente por el fabricante, el operador de red móvil y el proveedor de servicios. Diferentes consorcios pueden utilizar las mismas tecnologías de cadena de bloques para gestionar dispositivos IoT, ya sea dentro de un mismo país o a escala internacional. Cada uno de ellos puede desplegar o mantener uno o varios nodos pares de cadena de bloques, con arreglo al acuerdo que establezcan (este acuerdo suele aplicarse como una política de la función de gestión del servicio de membresía en las cadenas de bloques de consorcio).

El almacenamiento de toda la información conexa necesaria para las instalaciones sin intervención directamente en la cadena de bloques [b-UIT-T Y.4464] hace que esta sea bastante pesada y puede reducir su capacidad en términos de transacciones por segundo (TPS), ya que normalmente la velocidad de procesamiento se ve afectada por el tamaño de los datos. Esta tecnología no puede desarrollarse si el número máximo de transacciones por segundo es reducido. Por tanto, es preciso maximizar la eficiencia de la plataforma de cadena de bloques utilizada con ayuda no sólo de mecanismos de gestión de la privacidad, sino también de algoritmos de consenso eficientes desde un punto de vista energético. Tal como se ha mencionado anteriormente, en instalaciones sin intervención es necesario cargar en la cadena de bloques numerosos elementos de información por cada dispositivo. Consecuentemente, se recomienda cargar en la cadena de bloques solo el valor hash de la información, y almacenar la información propiamente dicha en el sistema de archivos interplanetario (IPFS). Sin embargo, la utilización del IPFS es optativa y toda la información puede almacenarse directamente en la cadena de bloques. Para gestionar la correspondencia entre la identidad y la propiedad de un dispositivo, se despliega un nodo de base de datos que permite extraer la información de identidad y almacenarla en la cadena de bloques. Con la ayuda de una base de datos, un nodo de control de acceso puede recuperar rápidamente de la base de datos la información fundamental de un dispositivo.



X.1353(22)

Figura 2 – Plataforma de instalación sin intervención con cuatro nodos pares de cadena de bloques

La Figura 2 muestra una arquitectura diseñada utilizando una cadena de bloques de consorcio. Una plataforma de instalación sin intervención debe constar de un nodo par de cadena de bloques, varios nodos pares IPFS, un nodo de base de datos (DB) y un nodo de control de acceso. Las funcionalidades de cada nodo son las siguientes:

- **Nodos pares de cadena de bloques:** los nodos de cadena de bloques de cada una de las partes están conectados entre sí y forman una cadena de bloques de consorcio. En particular, el sistema de cadena de bloques debe admitir contratos inteligentes, que son códigos de cadena publicados en la cadena de bloques. Proporcionan una forma transparente, fiable y automática de ejecutar transacciones y procesar los datos, que constituye una parte crucial de instalaciones sin intervención. El contrato inteligente se utiliza para el registro de dispositivos y la transferencia de la propiedad. Los fabricantes o los propietarios de los dispositivos pueden acceder al contrato inteligente para registrar nuevos dispositivos o actualizar las propiedades básicas de los mismos, incluida la propiedad y el valor hash del perfil de identidad, entre otros. Vincula la clave pública del dispositivo, la clave pública del propietario y el valor hash del perfil de identidad y crea un registro de transacción inmutable en la cadena de bloques. El contrato inteligente deberá soportar el registro del dispositivo, la transferencia de la propiedad y la actualización del perfil de identidad. Toma parámetros como la clave pública del dispositivo, la clave pública del propietario y el hash del perfil de identidad. Proporciona al menos cuatro funciones, incluyendo una función para la inicialización del contrato inteligente, el registro del dispositivo, la actualización del perfil del dispositivo y la transferencia de propietario. En el Apéndice I puede encontrarse un ejemplo de diseño de contrato inteligente.
- **Nodos pares IPFS:** los nodos IPFS de las diferentes partes están conectados entre sí y forman un sistema de archivos descentralizado. Los perfiles de identidad se almacenan en el IPFS y los valores hash de los perfiles se almacenan en la cadena de bloques. El sistema IPFS solo es accesible a través del nodo de control de acceso.

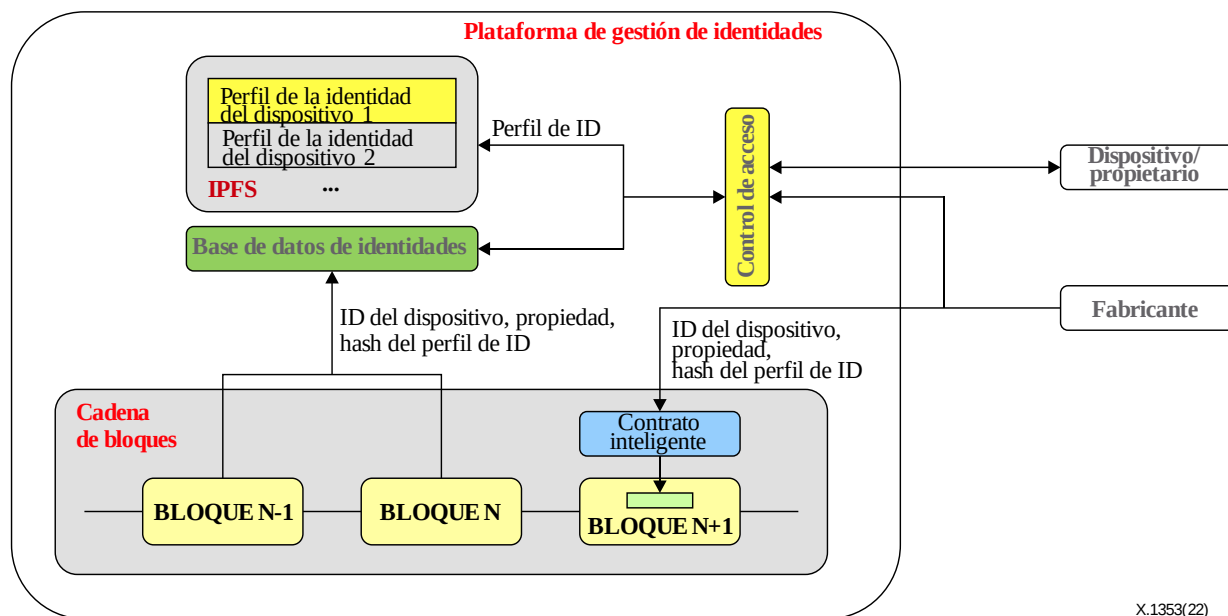
El perfil de identidad de un dispositivo contiene la información necesaria para permitir instalaciones sin intervención. Debe incluir la siguiente información:

- **Clave de identificación del dispositivo** (obligatoria): clave pública del dispositivo incluida en la identidad permanente del mismo, como una clave pública dentro del identificador de dispositivo inicial (IDevID) EIII 802.1AR [b-IEEE 802.1AR] o el certificado [b-UIT-T X.509] facilitado por el fabricante.
- **Hash del certificado del dispositivo:** valor resultado de la aplicación de la función hash al certificado del dispositivo. Este valor se utiliza para verificar el certificado del dispositivo.
- **Clave pública del propietario** (obligatoria): clave pública que identifica al propietario del dispositivo. El propietario utiliza la clave pública para acceder al contrato inteligente.
- **Hash del certificado del propietario:** valor resultado de la aplicación de la función hash al certificado del propietario. Este valor se utiliza para verificar el certificado del propietario.
- **Certificado del fabricante:** certificado del fabricante del dispositivo que firma el certificado del dispositivo. Si es un certificado intermedio, debería contener todos los certificados intermedios hasta el certificado raíz.
- **Perfil del operador de red** (opcional): perfil del operador de red. Un dispositivo accede a la red sobre la base de este perfil. El perfil puede contener el nombre del operador de red, el certificado del operador de red y una credencial que puede utilizar el dispositivo para autenticarse ante la red, por ejemplo, un identificador y una clave simétrica. En esta Recomendación no se define el formato exacto del perfil.

- **Perfil del proveedor de servicios** (opcional): perfil de un proveedor de servicios. Un dispositivo accede a una red de servicios sobre la base de este perfil. El perfil puede contener el nombre del operador del servicio, el nombre de dominio, el certificado del proveedor de servicios y una credencial que puede utilizar el dispositivo para autenticarse ante la red, por ejemplo, un identificador y una clave simétrica. En esta Recomendación no se define el formato exacto de este perfil.
- **Perfil del contrato inteligente:** perfil del contrato inteligente. Lo utiliza el propietario para gestionar el dispositivo cuando actualiza el perfil de identidad, incluida la transferencia de la propiedad. Puede contener la dirección del contrato inteligente y la interfaz binaria de la aplicación del contrato inteligente (ABI).
- **Nodo de control de acceso:** los nodos de control de acceso se despliegan para controlar quién puede acceder a la información de identidad almacenada en el IPFS. Los dispositivos se provisionan con una lista de identificadores uniformes de recursos (URI) de los nodos de control de acceso. Los nodos de control de acceso autentican al usuario mediante certificados. La clave pública del dispositivo o la que incluye el certificado del propietario se encuentra en la base de datos. Los nodos de control de acceso pueden recuperar de la base de datos la información sobre la propiedad del dispositivo y determinar si el usuario tiene permiso para acceder al archivo. En el Apéndice II a esta Recomendación se incluye una descripción detallada de cómo los usuarios acceden al perfil de identidad. Los nodos de control de acceso funcionan de forma independiente entre sí. El fabricante de los dispositivos puede configurar una lista de nombres de dominio para los nodos de control de acceso.
- **Nodo de base de datos:** los nodos de base de datos extraen la información de identidad de los bloques y la almacenan en la base de datos. En la plataforma diseñada, los datos de identidad se almacenan en el campo de datos de una transacción. Como el sistema de cadena de bloques puede utilizarse para otros fines, el nodo de base de datos puede filtrar los datos de los bloques sobre la base de las direcciones de los contratos inteligentes registrados en el nodo de base de datos. Si la dirección de la transacción no se corresponde con el contrato inteligente especificado, el nodo de base de datos no realiza las transacciones.

Para proteger la privacidad de los dispositivos, cada transacción solo contiene la información necesaria relativa a un dispositivo, como la clave pública del mismo, la clave pública del propietario y el hash del perfil de identidad. Cada dispositivo se identifica unívocamente mediante su clave pública de dispositivo y, por lo tanto, la base de datos solo mantiene un registro por dispositivo. El registro de un dispositivo se crea cuando su propietario lo registra en virtud de un contrato inteligente. La base de datos garantizará que no contiene ningún otro registro con la misma clave pública. Cuando se actualiza un registro, la base de datos debe garantizar que la actualización procede de su propietario.

Al igual que los nodos de control de acceso, los nodos de base de datos también trabajan de forma independiente.



X.1353(22)

Figura 3 – Módulos funcionales de la plataforma de instalación sin intervención

La Figura 3 presenta una vista lógica de los módulos funcionales de la plataforma de identidad sin intervención. El fabricante registra los dispositivos en la cadena de bloques y carga el perfil de identidad inicial en el IPFS. El dispositivo, el fabricante y el propietario pueden acceder al perfil de identidad a través del módulo de control de acceso.

7.2 Requisitos de seguridad

Cuando se construye e implementa una plataforma de instalación sin intervención, conviene tener en cuenta desde el principio las cuestiones relativas a la seguridad y la privacidad. Los requisitos de seguridad de una plataforma de instalación sin intervención son los siguientes.

- **Disponibilidad del sistema:** los usuarios de la plataforma de instalación sin intervención deben poder acceder a la plataforma y a los datos en cualquier momento. La disponibilidad hace referencia a las dos situaciones siguientes. En primer lugar, la plataforma debería estar disponible en todo momento para que todas las partes puedan cargar su información de ventas y su información de suscripción. En segundo lugar, los dispositivos autorizados deben poder acceder a los datos de las transacciones.
- **Resiliencia del sistema:** la resiliencia permite a una plataforma de instalación sin intervención continuar las operaciones y responder rápidamente a cambios, demandas, interrupciones y amenazas internas y externas. En comparación con el sistema centralizado tradicional, que presenta un punto de fallo único, la cadena de bloques proporciona resiliencia operativa gracias a su redundancia integrada. Sin embargo, esto depende en gran medida del número de nodos de consenso y de la conectividad de la red. Por lo tanto, al diseñar una plataforma de instalación sin intervención, se garantizará un número mínimo de nodos de consenso a fin de cumplir los requisitos de resiliencia.

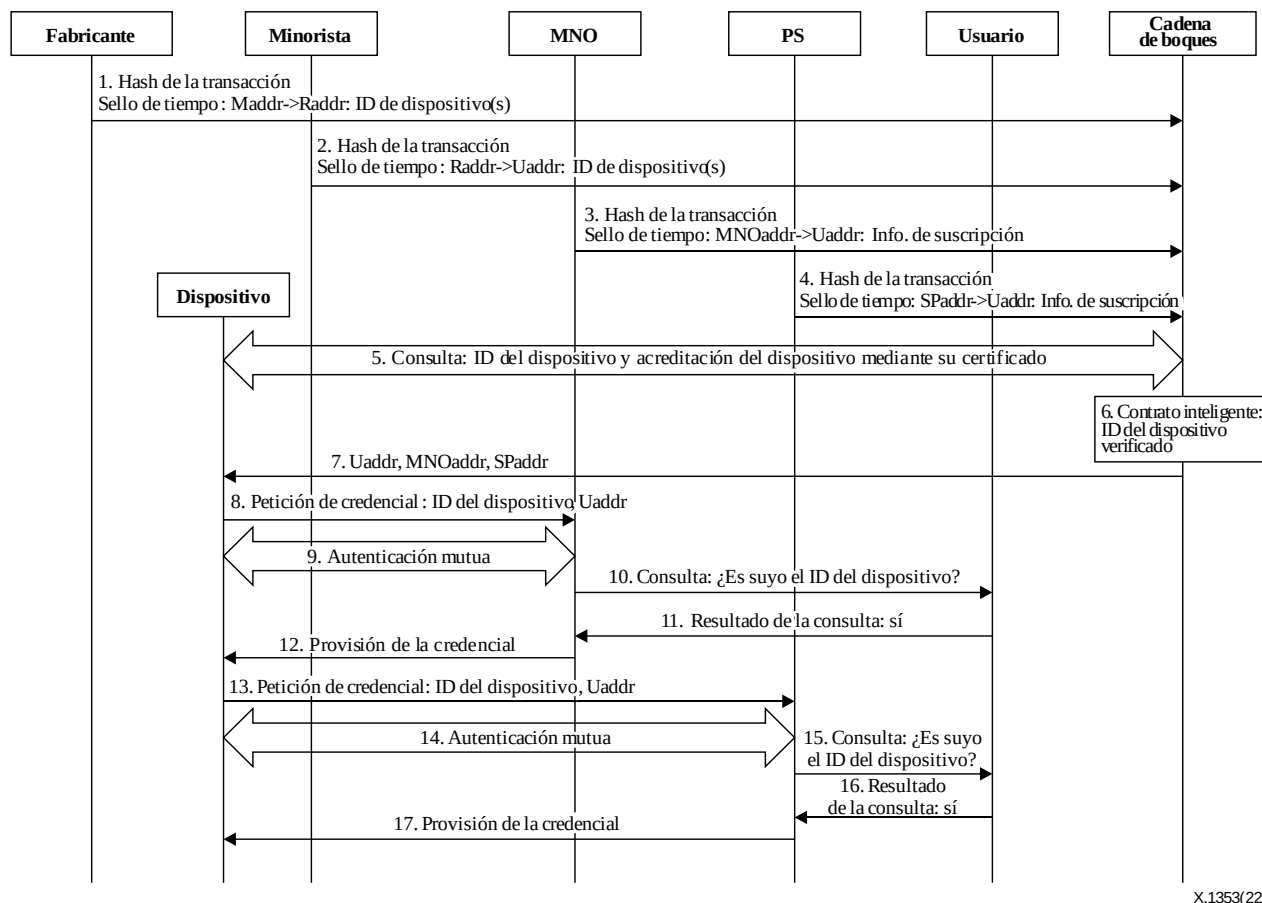
- **Confidencialidad de los datos:** aunque la cadena de bloques diseñada mediante primitivas criptográficas puede garantizar la integridad de los datos (inmutabilidad) mediante funciones hash y el no repudio mediante una firma digital, una cadena de bloques normal no puede proporcionar la confidencialidad de los datos, ya que los datos presentes en la cadena de bloques son transparentes y están disponibles para todos. Por lo tanto, en aquellos escenarios de aplicaciones en los que sea necesaria la confidencialidad de los datos, una plataforma de instalación sin intervención aplicará técnicas de encriptación y protección de la privacidad para garantizar la confidencialidad de los datos.
- **Integridad de los datos:** un rival puede interceptar la transmisión, modificar, falsificar y enviar paquetes falsos a la plataforma si no se tiene en cuenta la integridad de los datos durante la transmisión. Por lo tanto, la plataforma debería garantizar la integridad de los datos durante todo el proceso, incluyendo su almacenamiento, transmisión y utilización.
- **Seguridad de la clave:** todas las transacciones en la cadena de bloques están controladas por la clave privada. Por lo tanto, en una plataforma de instalación sin intervención, se garantizará la seguridad de las claves privadas de todas las partes (como la del operador de red móvil, el proveedor de servicios y el dispositivo). También se utilizará un entorno seguro de almacenamiento de claves (ya sea *software* o *hardware*) que garantice la seguridad de las claves.
- **Seguridad de los contratos inteligentes:** los contratos inteligentes son flexibles y ejecutan una lógica inmutable basada en un código de cadena previamente desplegada. Aunque esto ayuda a crear un ecosistema vibrante y creativo de sistemas automatizados interconectados de confianza, también ofrece a las atacantes oportunidades para explotar las vulnerabilidades de los contratos inteligentes. Normalmente, el código de un contrato inteligente no se puede modificar como sí ocurre con las actualizaciones y los parches tradicionales del *software*. Por lo tanto, la seguridad del contrato inteligente deberá garantizarse (por ejemplo, mediante la realización de auditorías estáticas y dinámicas, la verificación manual del código, etc.), es decir, deben considerarse todas las opciones posibles para verificar los códigos y cumplir los principios de desarrollo seguro (equivalentes a las etapas de desarrollo de los códigos de los contratos inteligentes).

8 Controles de seguridad para una instalación sin intervención basada en cadenas de bloques

En esta cláusula se abordan principalmente las consideraciones de seguridad para permitir una instalación sin intervención para la IoT masiva.

8.1 Diseño general del protocolo

La Figura 4 muestra el diseño general del protocolo.



X.1353(22)

Figura 4 – Procedimiento de instalación sin intervención

Paso 1: cuando un fabricante vende dispositivos a un minorista (o a un mayorista, ya que el procedimiento entre el mayorista y el minorista es el mismo en este procedimiento, no se describe por separado), carga la siguiente información básica en la plataforma de cadena de bloques:

- Hash de la transacción:** valores hash de la transacción.
- Sello de tiempo:** hora de creación de la transacción.
- Maddr:** dirección de la cadena de bloques del fabricante.
- Raddr:** dirección de la cadena de bloques del minorista.
- ID de dispositivos:** identidades de los dispositivos vendidos al minorista.

Paso 2: cuando un minorista vende los dispositivos a un usuario, también tiene que cargar la información conexa en la plataforma de cadena de bloques:

- Hash de la transacción:** valores hash de esta transacción.
- Sello de tiempo:** hora de creación de esta transacción.
- Raddr:** dirección de la cadena de bloques del minorista.
- Uaddr:** dirección de la cadena de bloques del usuario.
- ID de dispositivos:** identidades de los dispositivos vendidos al minorista.

Paso 3: cuando un usuario realiza la suscripción de un acceso de red con el operador de red móvil, el MNO tiene que cargar la información conexa en la plataforma de cadena de bloques:

- Hash de la transacción:** valores hash de esta transacción.
- Sello de tiempo:** hora de creación de esta transacción.
- MNOaddr:** dirección de la cadena de bloques del operador de red móvil.

- d) **Uaddr:** dirección de la cadena de bloques del usuario.
- e) **Info. de la suscripción:** información de la suscripción del usuario.

Paso 4: cuando un usuario realiza la suscripción de un servicio con el proveedor de servicios, el proveedor de servicios tiene que cargar la información conexa en la plataforma de cadena de bloques:

- a) **Hash de la transacción:** valores hash de esta transacción.
- b) **Sello de tiempo:** hora de creación de esta transacción.
- c) **SPaddr:** dirección de la cadena de bloques del proveedor de servicios.
- d) **Uaddr:** dirección de la cadena de bloques del usuario.
- e) **Info. de la suscripción:** información de la suscripción de este usuario.

Paso 5: cuando se enciende un dispositivo, este accede a la cadena de bloques utilizando la dirección preinstalada de la cadena de bloques. El dispositivo tiene que demostrar a la plataforma de cadena de bloques su identidad utilizando su certificado preinstalado en el procedimiento de fabricación, procedimiento conocido como acreditación del dispositivo. En la cláusula 8.2 se incluye información sobre el procedimiento de acreditación. Tras la acreditación del dispositivo, este puede iniciar una operación de consulta a la cadena de bloques.

Paso 6: una vez que la cadena de bloques ha verificado la identidad del dispositivo, buscará al propietario del dispositivo (el usuario que compró este dispositivo) así como al operador de red móvil y al proveedor de servicios al que se suscribió el propietario del dispositivo (este paso puede implementarse utilizando un contrato inteligente).

Paso 7: la cadena de bloques devuelve al dispositivo un mensaje, que incluye Uaddr, MNOaddr y SPaddr.

Paso 8: el dispositivo envía un mensaje de solicitud de credenciales al operador de red móvil (MNO) basado en la MNOaddr recibida en el mensaje anterior. Este mensaje de solicitud de credenciales debe incluir el ID del dispositivo y la Uaddr.

Paso 9: una vez que el MNO ha recibido el mensaje de solicitud de credencial, inicia una autenticación mutua con el dispositivo. El propósito de esta autenticación mutua es garantizar que el dispositivo y el MNO verifiquen las identidades de ambas partes y negocien la clave de encriptación e integridad para su uso futuro.

Paso 10: el MNO inicia una consulta al usuario basándose en la Uaddr recibida. El mensaje de consulta preguntará si un determinado dispositivo (por ejemplo, el ID del dispositivo) pertenece al usuario. El mensaje de consulta puede enviarse como un mensaje corto o mediante un mensaje del panel de control

Paso 11: el usuario responde sí o no al mensaje de consulta. Si la respuesta es negativa, el MNO rechaza la solicitud de credenciales del dispositivo. Si la respuesta es afirmativa, el proceso continúa con el paso siguiente.

Paso 12: en caso afirmativo, el MNO inicia el proceso de provisión de la credencial.

Paso 13: el dispositivo envía un mensaje de solicitud de credenciales al proveedor de servicios basado en la SPaddr recibida en un mensaje previo. Este mensaje de solicitud de credenciales debe incluir el ID del dispositivo y la Uaddr.

Paso 14: una vez que el proveedor de servicios recibe el mensaje de solicitud de credenciales, inicia una autenticación mutua con el dispositivo. El propósito de esta autenticación mutua es garantizar que el dispositivo y el proveedor de servicios verifiquen las identidades de ambas partes y negocien la clave de encriptación e integridad para su uso futuro.

Paso 15: el proveedor de servicios realiza una consulta al usuario basándose en la Uaddr recibida. El mensaje de consulta pregunta si el dispositivo (por ejemplo, el ID del dispositivo) pertenece a dicho usuario. El mensaje de consulta puede transmitirse como un mensaje corto o mediante una aplicación (APP).

Paso 16: el usuario responde sí o no al mensaje de consulta. Si la respuesta es negativa, el proveedor de servicios rechaza la solicitud de credenciales del dispositivo. Si la respuesta es afirmativa, el proceso continúa con el paso siguiente.

Paso 17: en caso afirmativo, el proveedor de servicios inicia el proceso de provisión de la credencial.

8.2 Acreditación del dispositivo

La acreditación del dispositivo es el procedimiento por el que la cadena de bloques (el contrato inteligente) verifica la identidad de un dispositivo. La acreditación del dispositivo es necesaria porque la cadena de bloques (el contrato inteligente) debe conocer la identidad del dispositivo antes de encontrar y enviar la información sensible conexa (por ejemplo, el MNO y el proveedor de servicios de su propietario). Esto es importante como medida de protección frente a dispositivos bajo el control de personas con intenciones maliciosas.

En este contexto, la acreditación del dispositivo difiere de la acreditación convencional de dispositivos, que incluye la acreditación de *software* y de *hardware*. La acreditación del *software* verifica la funcionalidad del código en el dispositivo, y la acreditación del *hardware* se centra en validar la autenticidad y la fiabilidad del *hardware*. En este caso, la acreditación del dispositivo se refiere fundamentalmente a la acreditación de su identidad, que permite al dispositivo proporcionar una prueba de su identificador del *hardware*, como su número de serie o la identidad internacional del equipo móvil (IMEI).

La acreditación del dispositivo puede realizarse mediante la credencial inicial preinstalada en el mismo. El procedimiento de acreditación no depende del tipo de cadena de bloques, pero sí del protocolo de acreditación elegido por el consorcio. Diferentes consorcios pueden elegir el mismo protocolo de acreditación.

8.3 Autenticación

La autenticación se refiere aquí a la autenticación mutua entre el dispositivo y el MNO, véase el paso 9 de la Figura 4, y entre el dispositivo y el proveedor de servicios, véase el paso 14 de la Figura 4. El propósito de este procedimiento es permitir que el MNO o el proveedor de servicios verifiquen la identidad del dispositivo, y que, a su vez, el dispositivo verifique las identidades del MNO y del proveedor de servicios. Esto es importante como protección frente a posibles problemas de seguridad debidos a dispositivos que se encuentren bajo el control de personas con intenciones maliciosas que se hacen pasar por otros dispositivos legítimos, y para evitar que dispositivos legítimos confíen en MNO y proveedores de servicios suplantados.

La autenticación mutua puede basarse en las credenciales preinstaladas en el dispositivo, así como en las credenciales del MNO y el proveedor de servicios.

Los procedimientos de autenticación y generación de claves acordadas y los mecanismos de protección criptográfica necesarios para garantizar la seguridad de las plataformas de instalación sin intervención de la IoT masiva basadas en cadenas de bloques deberían permitir la aplicación de los procedimientos y mecanismos propuestos utilizando medios certificados de protección criptográfica que apliquen las normas nacionales en la materia.

8.4 Provisión de credenciales

Para acceder a la red celular, el dispositivo debe obtener credenciales del MNO. En las redes celulares actuales, incluidas las IMT-Avanzadas y las IMT-2020, la credencial suele adoptar la forma de una identidad (por ejemplo, la identidad de abonado móvil internacional (IMSI)) junto con una clave simétrica. Para acceder a la plataforma de servicios, el dispositivo necesita obtener credenciales del proveedor de servicios. En la mayoría de las plataformas de servicios IoT actuales, la credencial suele tener la forma de nombre de usuario y contraseña, o también de una identidad y una clave simétrica. Dado que las credenciales son informaciones secretas, es necesario establecer un túnel seguro antes de la transmisión de credenciales. Para establecer el túnel seguro, se debe llevar a cabo primero la autenticación mutua descrita en la cláusula 8.3. Para permitir la provisión de credenciales, es necesario implementar protocolos de provisión de credenciales entre el dispositivo y el MNO o el proveedor de servicios. Si el dispositivo está equipado con una tarjeta de circuitos integrados universal integrada (eUICC), las claves se suministran a distancia a la eUICC, ya que dichas claves se instalan conforme a la especificación actual de provisión de claves a distancia recogida en [b-GSMA SGP.02]. La información sobre los papeles desempeñados, las funciones asociadas y las interfaces de la provisión a distancia de eUICC pueden encontrarse en [b-GSMA SGP.02]. La especificación del perfil, el formato de almacenamiento y la utilización de esas claves en la eUICC está fuera del alcance de esta Recomendación.

En la Figura 5 se muestra una arquitectura general para dispositivos IoT sin eUICC que permite el suministro de credenciales. Los principales componentes son los siguientes:

- Sistema de gestión de claves (KMS): entidad que proporciona el servicio de generación de claves, es decir, genera las claves simétricas que se provisionarán en los dispositivos.
- Proveedor de identidad (IdP): entidad que crea, mantiene y gestiona información de identidad y encapsula la identidad generada con la información de la clave como una credencial intacta.
- Módulo de seguridad (SecM): elemento que puede almacenar claves de forma segura y ejecutar con ellas mecanismos de seguridad para completar operaciones de seguridad. Un dispositivo IoT debe tener un módulo de seguridad.
- Centro de autenticación (AuC): ofrece la autenticación de entidades como un servicio.

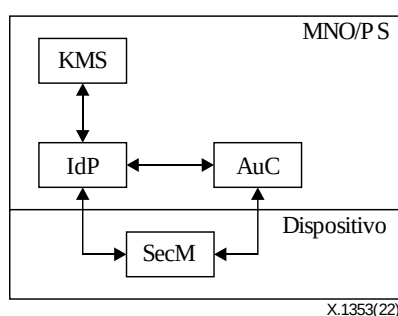


Figura 5 – Arquitectura de la provisión de claves para dispositivos no eUICC

El IdP utiliza el servicio de autenticación que proporciona el AuC para autenticar los dispositivos. Tras la autenticación mutua definida en la cláusula 8.3, el IdP presta el servicio de provisión de identidad al SecM, que incluye la creación, designación, sustitución y revocación de la identidad. Tras crear y designar una nueva identidad para un dispositivo, el IdP invoca el servicio de generación de clave que presta el KMS para generar la clave simétrica para el identificador recién atribuido y distribuir las claves al SecM de forma segura. El AuC crea un canal seguro entre el IdP y el SecM para facilitar la provisión de la identidad que ha proporcionado el IdP.

9 Protección de los datos de identificación

Para permitir instalaciones de dispositivos sin intervención, deben almacenarse en la plataforma de cadena de bloques algunos datos de identificación, como el certificado del dispositivo, el certificado del fabricante, el código de operador y el certificado del operador.

Para proteger la información a fin de que no sea transferida a partes no autorizadas, es necesario encriptar parte de ella, incluso si la cadena de bloques es una cadena de bloques basada en permisos.

9.1 Datos de identificación

Para permitir instalaciones sin intervención de dispositivos y facilitar al propietario la gestión de sus dispositivos, es necesario proporcionar al dispositivo algunos atributos de identidad conexos. Se han identificado algunos atributos que deben almacenarse en la plataforma de gestión de identidades, ya sea en datos de transacciones o en los perfiles de identidad de dispositivos:

- **Clave pública del dispositivo:** esta clave pública identifica de forma unívoca al dispositivo. Se almacena en la cadena de bloques mediante registro y se mantiene sin cambios. La clave pública del dispositivo está en texto no encriptado. La clave pública es un número aleatorio. Deberá ser la misma que la clave pública del certificado del dispositivo.
- **Clave pública del propietario:** esta clave pública identifica de forma unívoca al propietario del dispositivo. La clave pública del propietario está en texto no encriptado. Esta clave es la misma que la clave pública del certificado del propietario.
- **Elemento de información del operador de red:** este elemento de información determina el operador al que debe conectarse el dispositivo para el acceso a la red. Debe incluir la identidad del operador, como el código del operador, el nombre de la red y el certificado del operador. Este elemento de información debe encriptarse.
- **Elemento de información del fabricante:** este elemento de información incluye el nombre del fabricante, el enlace de red para soporte técnico y el certificado del fabricante. Este elemento de información debe encriptarse.
- **Dirección del contrato inteligente:** contrato inteligente que puede utilizarse para gestionar la identidad del dispositivo. Este elemento de información puede ser texto no encriptado.
- **ABI del contrato inteligente:** este elemento de información debe ser texto no encriptado.

9.2 Requisitos de protección de los datos de identificación

Para garantizar su protección, todos los datos de identificación de un dispositivo deberían incluirse en primer lugar en un único archivo, denominado perfil de identidad. El perfil se codifica en formato JSON como `{{IDENTITY PROFILE: ITU-T x.abcd ver x.xx}, {public key encryption algorithm: oid}, {Share Key encryption: oid}, ..., {}}`, donde el PERFIL DE IDENTIDAD (IDENTITY PROFILE) se identifica por el número de la Recomendación UIT-T más el número de la versión.

Además, los datos de identificación deberían encriptarse con una clave compartida. Para que el propietario del dispositivo o el propio dispositivo puedan acceder a la información, el propietario debería generar una clave compartida que debería encriptarse con la clave pública del dispositivo y del propietario del dispositivo. Para encriptar la clave compartida se pueden utilizar diferentes tecnologías de clave pública, como RSA, el esquema de encriptación integrado de curva elíptica (ECIES) y la encriptación basada en atributos (ABE). En esta Recomendación no se especifican los métodos exactos de encriptación de la clave compartida y los datos de identificación.

Apéndice I

Contrato inteligente para la gestión de la identidad de los dispositivos

(Este apéndice no forma parte integrante de la presente Recomendación.)

El Cuadro I.1 muestra un ejemplo de diseño de un contrato inteligente basado en la cadena de bloques de ethereum.

Cuadro I.1 – Interfaces del contrato inteligente de gestión de dispositivos

Nº	Nombre de la interfaz	Parámetros	Descripción
1	Constructor	1 MaximumNumberOfDevices 2 OwnerAddress	1 MaximumNumberOfDevices: establece el número máximo de dispositivos que puede gestionar este contrato. El parámetro puede ser opcional. 2 OwnerAddress: dirección de la cartera del propietario. Si se proporciona el propietario, solo este puede registrar los dispositivos. La llamada a esta función se hace una sola vez, cuando se despliega el contrato inteligente.
2	Registro	1 DeviceIdentificationKey 2 OwnerIdentificationKey	1 DeviceIdentificationKey: clave pública de los dispositivos registrados. Debe ser la misma que la clave pública del certificado de identidad del dispositivo proporcionado por el fabricante. 2 OwnerIdentificationKey: clave pública del propietario del dispositivo. La llamada a esta función se hace cuando el fabricante/propietario registra un dispositivo.
3	UpdateHash	1 DeviceIdentificationKey 2 Hash	1 DeviceIdentificationKey: clave pública registrada para un dispositivo. 2 Hash: hash del perfil de identidad. La llamada a esta función se hace cuando se crea un perfil de identidad para una actualización.
4	UpdateOwner	1 DeviceIdentificationKey 2 OwnerIdentificationKey 3 Hash	1 DeviceIdentificationKey: clave pública registrada para un dispositivo. 2 OwnerIdentificationKey: clave pública del propietario. La llamada a esta función se hace cuando los dispositivos se transfieren a un nuevo propietario. 3 Hash: valor hash del nuevo perfil.

Apéndice II

Procedimientos de gestión de dispositivos

(Este apéndice no forma parte integrante de la presente Recomendación.)

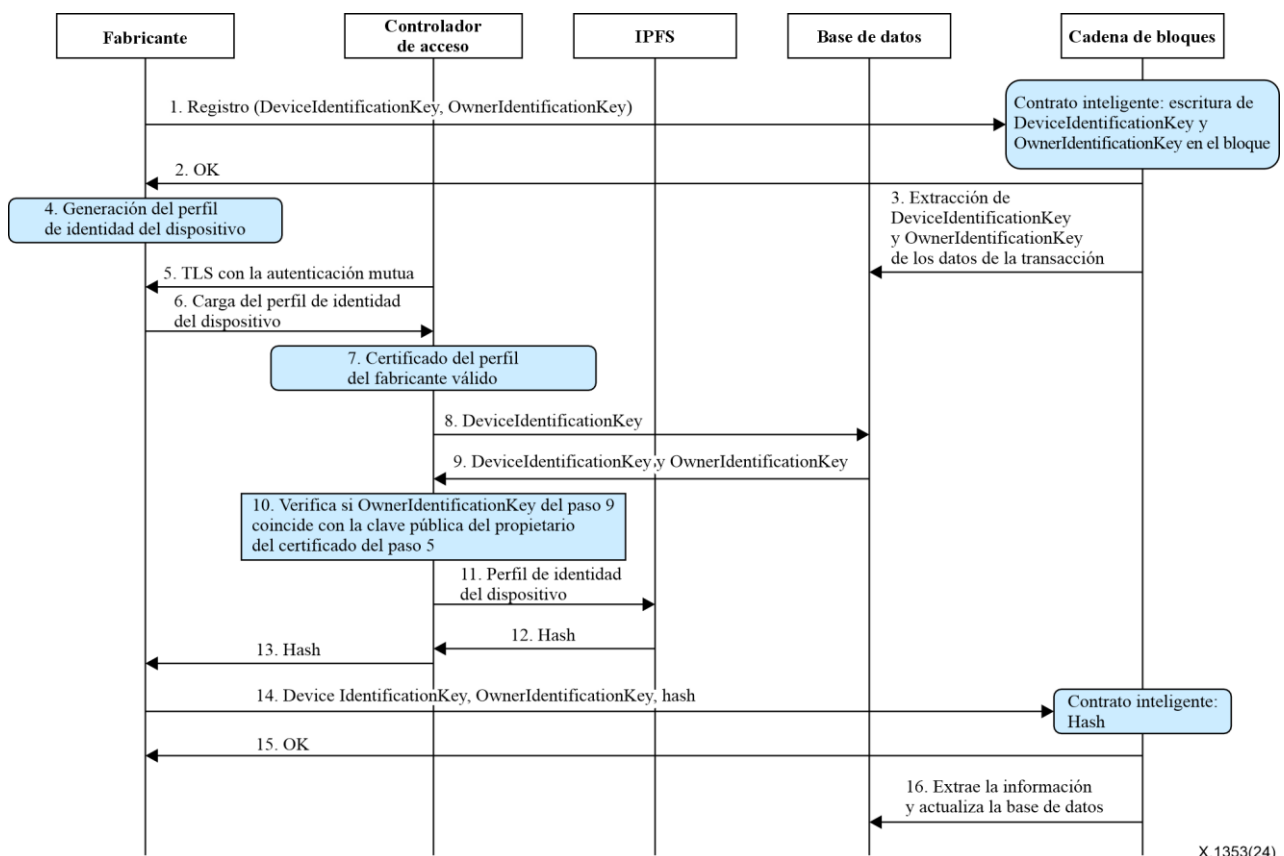
II.1 Introducción

Tal como se especifica en la cláusula 7.1.5, el nodo de control de acceso se despliega para proteger la información del perfil de identidad y para que solo las entidades autorizadas, como el propietario del dispositivo y el propio dispositivo, puedan acceder al perfil de identidad. En este apéndice se especifica la integración del control de acceso con los procedimientos de registro de dispositivos, la transferencia de la propiedad, la actualización del perfil del dispositivo y la recuperación del perfil desde la plataforma descentralizada de gestión de la identidad.

II.2 Creación del perfil de identidad

El propietario del dispositivo crea el perfil de identidad cuando el fabricante produce un nuevo dispositivo. El fabricante accede al contrato inteligente y registra el dispositivo en la cadena de bloques. A continuación, el propietario del dispositivo crea y carga el perfil de identidad del dispositivo en el sistema IPFS con la ayuda de un sistema de control del acceso. Una vez que se recibe el código hash generado por el sistema IPFS, el propietario del dispositivo accede de nuevo al contrato inteligente y carga el código hash del perfil en la cadena de bloques.

Para proteger la privacidad de la identidad del dispositivo, solo se incluyen en la cadena de bloques la clave pública del dispositivo, la clave pública del propietario y el hash del perfil de identidad. La Figura II.1 muestra el procedimiento por el que el propietario de un dispositivo crea un perfil de identidad cuando registra el dispositivo en la plataforma.



X.1353(24)

Figura II.1 – Procedimiento de registro de un dispositivo

Procedimiento de registro del dispositivo:

- 1) El fabricante accede a la interfaz de registro del contrato inteligente y pasa DeviceIdentificationKey y OwnerIdentificationKey como parámetros para el contrato inteligente. El valor de DeviceIdentificationKey será el mismo que el de la identidad permanente del dispositivo, es decir, el certificado del dispositivo emitido por el fabricante durante el proceso de fabricación.
- 2) La cadena de bloques devuelve los resultados una vez finalizada la transacción. Las claves públicas del dispositivo y del propietario se registran en el campo de datos de una transacción.
- 3) La base de datos escanea el bloque recién generado, extrae los datos de la transacción y los añade a la base de datos. Cuando la base de datos incluye en su tabla el registro de un dispositivo, comprueba si la clave pública del dispositivo está en la base de datos. Si ya está presente, eliminará los datos de la transacción. Si no hay ningún registro con la misma clave pública de dispositivo, se creará un nuevo registro y la clave pública del dispositivo, la clave pública del propietario, la dirección del contrato y el ABI del contrato, se incluirán en la base de datos como un nuevo registro.
- 4) Una vez registrada la DeviceIdentificationKey en la cadena de bloques, el fabricante crea un perfil de identidad con los campos especificados en el Cuadro I.1.
- 5) El fabricante aplica el protocolo de seguridad de la capa de transporte (TLS) para establecer una conexión con el controlador de acceso. Se requiere autenticación mutua. La clave pública del certificado del fabricante deberá coincidir con la OwnerIdentificationKey registrada en la cadena de bloques para el dispositivo correspondiente.
- 6) El fabricante carga el perfil de identidad.
- 7) El controlador de acceso verifica el perfil de identidad comparando la OwnerIdentificationKey del perfil de identidad con la clave pública del certificado en la conexión TLS. Si coinciden, el controlador de acceso verifica además la firma del perfil de identidad con la OwnerIdentificationKey. Si la verificación de la firma es positiva, el proceso pasa al siguiente paso.
- 8) El controlador de acceso realiza una consulta a la base de datos con la DeviceIdentificationKey del perfil de identidad.
- 9) La base de datos busca en su tabla en base a la DeviceIdentificationKey y devuelve la DeviceIdentificationKey junto con la OwnerIdentificationKey de la base de datos sobre la base del registro más reciente.
- 10) El controlador de acceso verifica si la OwnerIdentificationKey del paso 9 es la misma que la del paso 5; si son iguales, continúa con el paso 11.
- 11) El controlador de acceso carga los perfiles de identidad en el sistema IPFS.
- 12) El sistema IPFS devuelve al controlador de acceso el código hash del perfil de identidad cargado.
- 13) El controlador de acceso envía el código hash del perfil de identidad al fabricante.
- 14) El fabricante hace una llamada a la interfaz UpdateHash del contrato inteligente con la clave pública del dispositivo y el hash del perfil. La función UpdateHash del contrato inteligente registra la clave pública del dispositivo y el hash como datos de la transacción en el bloque.
- 15) La cadena de bloques devuelve una confirmación (OK) al fabricante.

- 16) La base de datos escanea el bloque y crea un nuevo registro basado en la información del registro más reciente de la base de datos, actualizando el valor hash del perfil de identidad. La base de datos del sistema de gestión de identidades diseñado es de tipo "append only" (solo se permiten adiciones), lo que significa que nunca se borrará ningún registro.

II.3 Recuperación del perfil de identidad

El perfil de identidad puede ser recuperado por los propietarios de los dispositivos o por los propios dispositivos.

II.3.1 El propietario del dispositivo recupera el perfil de identidad

Para recuperar el perfil de identidad de un dispositivo específico, el propietario del dispositivo puede elegir en primer lugar un controlador de acceso de una lista y luego establecer una conexión segura con el controlador de acceso. La conexión segura se establece con el protocolo TLS y se realiza entonces la autenticación mutua. La Figura II.2 muestra los procedimientos para recuperar los perfiles de identidad.

Recuperación del perfil de identidad por el propietario del dispositivo:

- 1) El propietario del dispositivo elige un controlador de acceso y establece una conexión TLS con el mismo. Se requiere autenticación mutua. La clave pública del certificado del propietario del dispositivo será la misma que la clave pública proporcionada en el procedimiento de registro.
- 2) El propietario del dispositivo envía DeviceIdentificationKey al controlador de acceso para recuperar el perfil de identidad. El formato del mensaje aún no se ha definido.
- 3) El controlador de acceso envía DeviceIdentificationKey a la base de datos para la recuperación del registro.
- 4) El nodo de base de datos busca en su base de datos y devuelve DeviceIdentificationKey, OwnerIdentificationKey y el hash para el perfil de identidad.
- 5) El controlador de acceso verifica la propiedad comparando la OwnerIdentificationKey del paso 4 y la clave pública del certificado del propietario del paso 1. Si la verificación es positiva, el proceso continúa en el paso 6.
- 6) El controlador de acceso envía el valor hash a un nodo IPFS seleccionado.
- 7) El nodo IPFS devuelve un perfil de identidad con arreglo al valor hash.
- 8) El controlador de acceso verifica DeviceIdentificationKey y OwnerIdentificationKey del perfil con las de la base de datos.
- 9) El controlador de acceso verifica además la integridad del perfil de identidad con OwnerIdentificationKey y la firma incluida en el perfil.
- 10) El controlador de acceso devuelve el perfil de identidad del dispositivo.

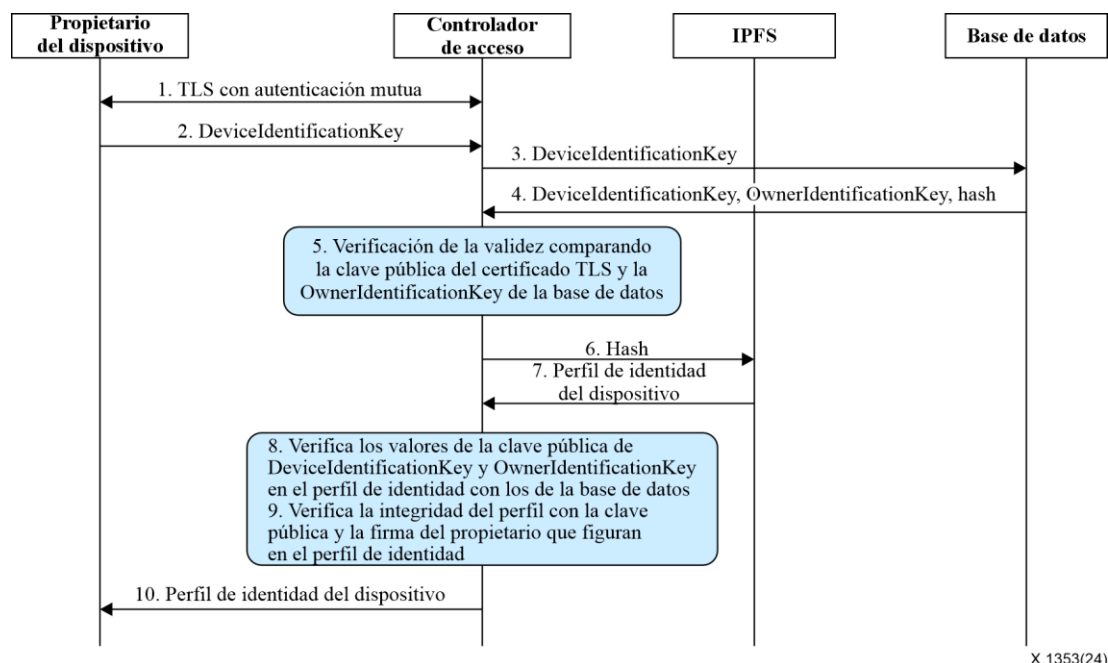


Figura II.2 – El propietario del dispositivo recupera el perfil de identidad del IPFS a través del controlador de acceso

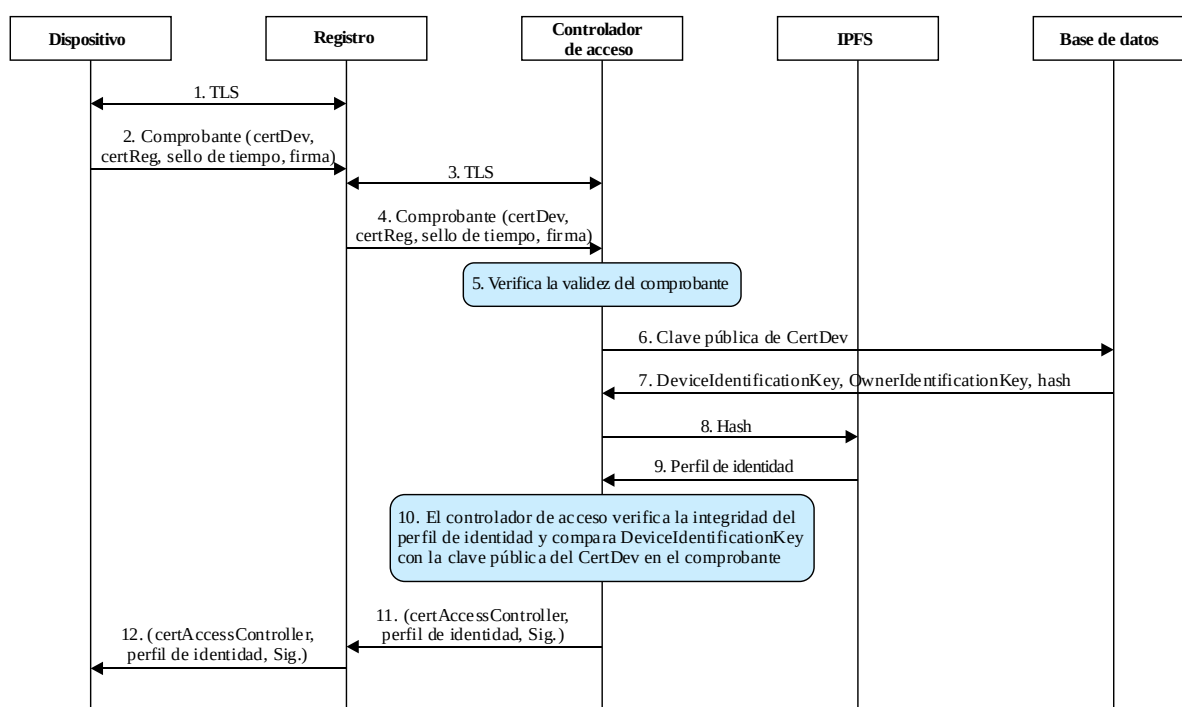
II.3.2 El dispositivo recupera el perfil de identidad

Del mismo modo, cuando el dispositivo necesita acceder a la red por primera vez, puede necesitar recuperar de la plataforma de gestión de identidades el perfil de identidad del dispositivo para saber a qué red debe conectarse. El acceso inicial a la red puede ser proporcionado por el cliente a través de una red local abierta con acceso limitado.

Una vez proporcionado el acceso inicial a la red, la Figura II.3 muestra el procedimiento para que un dispositivo recupere su perfil de identidad de la plataforma de gestión de identidades. Los procedimientos a seguir son los siguientes:

- 1) El dispositivo establece una conexión TLS con el registrador de la red.
- 2) El dispositivo genera un cupón o comprobante para la recuperación del perfil de identidad con su clave privada. El comprobante contiene el certificado del dispositivo, un sello de tiempo y una firma. Si el dispositivo no puede conectarse directamente al controlador de acceso, debe incluir también en su comprobante los certificados del nodo de retransmisión, es decir, el registrador en la figura.
- 3) El registrador establece una conexión TLS con el controlador de acceso elegido por el dispositivo.
- 4) El registrador envía el comprobante al controlador de acceso.
- 5) El controlador de acceso valida el comprobante.
- 6) El controlador de acceso envía la clave pública del dispositivo a la base de datos para recuperar el hash del perfil de identidad.
- 7) La base de datos devuelve la clave pública del dispositivo junto con el hash.
- 8) A continuación, el controlador de acceso envía el hash al IPFS.
- 9) El IPFS devuelve el perfil de identidad en base al hash proporcionado.

- 10) El controlador de acceso valida en primer lugar la integridad del perfil de identidad con la OwnerIdentificationKey y la firma contenida en el campo de firma del perfil de identidad; a continuación, compara DeviceIdentificationKey del perfil con la clave pública incluida en el certificado del dispositivo recibida en el comprobante y, si coinciden, el proceso continúa en el paso 11.
- 11) El controlador de acceso devuelve el perfil de identidad al registrador. Para garantizar la autenticidad del perfil de identidad, este puede enviarse con la firma del controlador de acceso.
- 12) El dispositivo verifica la firma proporcionada por el controlador de acceso con certAccessController. Si la verificación es positiva, el dispositivo extrae la información del perfil de identidad. El dispositivo también puede hacer una verificación con un controlador de acceso diferente y comparar el perfil de identidad para asegurarse de que no está siendo engañado por un controlador de acceso intervenido.



X.1353(22)

Figura II.3 – El dispositivo recupera el perfil de identidad de la plataforma de gestión de identidades

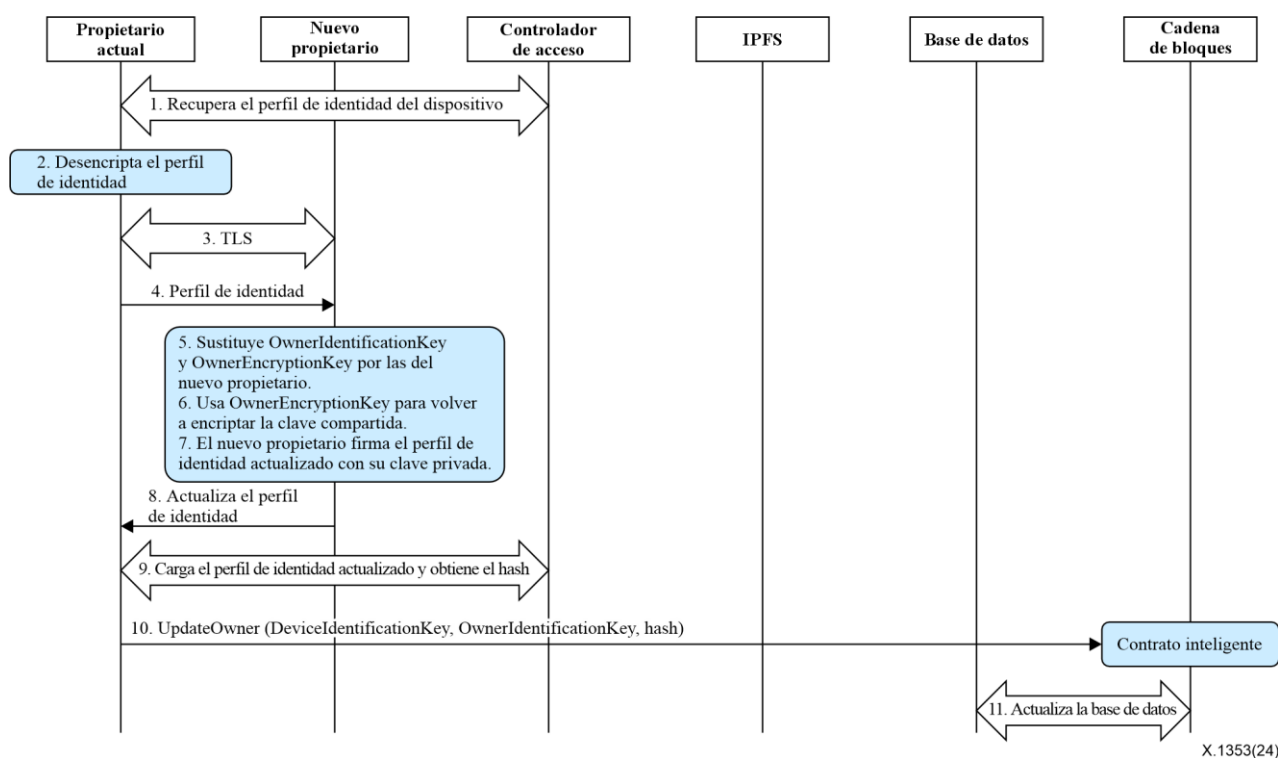
II.3.3 Transferencia de la propiedad

Como se ha mencionado anteriormente, la propiedad de un dispositivo puede ser transferida a un nuevo propietario cuando su actual propietario la vende, por ejemplo, el fabricante, o un minorista.

Para cambiar la propiedad, se seguirán los procedimientos de la Figura II.4. Los procedimientos son los siguientes:

- 1) El propietario actual recupera el perfil de identidad de un dispositivo específico. Se sigue el procedimiento definido en la cláusula II.3.1.
- 2) El propietario actual descripta el perfil de identidad con su clave privada.
- 3) El propietario actual establece un canal TLS seguro con el nuevo propietario. Se utiliza autenticación mutua. El propietario actual y el nuevo propietario conocen sus respectivos certificados a través de otro canal. La forma de intercambiar la información de certificados es función de la implementación y está fuera del alcance de la presente Recomendación.
- 4) El propietario actual envía un perfil de identidad descriptado al nuevo propietario.

- 5) El nuevo propietario sustituye OwnerIdentificationKey, OwnerEncryptionKey y OwnerCert por sus claves y su certificado, reemplazando los campos correspondientes en el perfil de identidad.
- 6) El nuevo propietario vuelve a encriptar la clave compartida con su clave de encriptación. Si se sustituye la clave compartida, todos los archivos afectados y la clave compartida con DeviceEncryptionKey deben volver a encriptarse.
- 7) El nuevo propietario firma el perfil de identidad con su clave privada.
- 8) El nuevo propietario envía el perfil de identidad actualizado al propietario actual.
- 9) El propietario actual carga el perfil de identidad actualizado en la plataforma del gestor de identidades a través del controlador de acceso.
- 10) El propietario actual actualiza la clave pública del propietario del dispositivo transferido mediante una llamada a la interfaz UpdateOwner especificada en la Figura II.4. En su llamada a la función de actualización del contrato inteligente incluye la DeviceIdentificationKey, OwnerIdentificationKey y el hash.
- 11) La base de datos agrega un nuevo registro para el dispositivo asociado en base a los datos de la transacción.



X.1353(24)

Figura II.4 – Procedimiento de transferencia de la propiedad

Bibliografía

- [b-UIT-T L.1317] Recomendación UIT-T L.1317 (2021), *Directrices sobre sistemas de cadenas de bloques de alta eficiencia energética*
- [b-UIT-T X.509] Recomendación UIT-T X.509 (2019), *Tecnología de la información – Interconexión de sistemas abiertos – El directorio: Marcos para certificados de claves públicas y atributos*
- [b-UIT-T X.800] Recomendación UIT-T X.800 (1991), *Arquitectura de seguridad de la interconexión de sistemas abiertos para aplicaciones del CCITT*
- [b-UIT-T X.1250] Recomendación UIT-T X.1250 (2009), *Capacidades básicas para una interoperabilidad y una gestión mejoradas de la identidad global*
- [b-UIT-T X.1254] Recomendación UIT-T X.1254 (2020), *Marco de garantía de autenticación de entidad*
- [b-UIT-T X.1365] Recomendación UIT-T X.1365 (2020), *Metodología de seguridad para el uso de criptografía basada en la identidad para dar soporte a servicios de Internet de las cosas por redes de telecomunicaciones*
- [b-UIT-T X.1400] Recomendación UIT-T X.1400 (2020), *Términos y definiciones sobre la tecnología de libro mayor distribuido*
- [b-UIT-T X.1411] Recomendación UIT-T X.1411 (2023), *Directrices sobre seguridad de la cadena de bloques como servicio (BaaS)*
- [b-UIT-T Y.3081] Recomendación UIT-T Y.3081 (2022), *Self-controlled identity based on blockchain – Requirements and framework*
- [b-UIT-T Y.4000] Recomendación UIT-T Y.4000/Y.2060 (2012), *Visión general de la Internet de las cosas*
- [b-UIT-T Y.4464] Recomendación UIT-T X.4464 (2020), *Framework of blockchain of things as decentralized service platform*
- [b-GSMA SGP.02] GSM Association Non-confidential Official Document SGP.02 (2023), *Remote provisioning architecture for embedded UICC technical specification. Versión 4.3*
<<https://www.gsma.com/solutions-and-impact/technologies/esim/wp-content/uploads/2023/02/SGP.02-v4.3.pdf>>
- [b-IEEE 802.1AR] IEEE 802.1AR-2018, *IEEE Standard for Local and metropolitan area networks – Secure Device Identity*
<[https://1.ieee802.org/security/802-1ar/#:~:text=Local%20Area%20Networks%20\(LANs\)%20are,run%20over%20the%20networks%20themselves.>](https://1.ieee802.org/security/802-1ar/#:~:text=Local%20Area%20Networks%20(LANs)%20are,run%20over%20the%20networks%20themselves.>)>
- [b-ISO/CEI 10027] ISO/IEC 10027:1990, *Information technology – Information Resource Dictionary System (IRDS) framework*
<<https://www.iso.org/standard/17985.html>>

SERIES DE RECOMENDACIONES DEL UIT-T

Serie A	Organización del trabajo del UIT-T
Serie D	Principios de tarificación y contabilidad y cuestiones económicas y políticas de las telecomunicaciones/TIC internacionales
Serie E	Explotación general de la red, servicio telefónico, explotación del servicio y factores humanos
Serie F	Servicios de telecomunicación no telefónicos
Serie G	Sistemas y medios de transmisión, sistemas y redes digitales
Serie H	Sistemas audiovisuales y multimedia
Serie I	Red digital de servicios integrados
Serie J	Redes de cable y transmisión de programas radiofónicos y televisivos, y de otras señales multimedia
Serie K	Protección contra las interferencias
Serie L	Medio ambiente y TIC, cambio climático, ciberdesechos, eficiencia energética, construcción, instalación y protección de los cables y demás elementos de planta exterior
Serie M	Gestión de las telecomunicaciones, incluida la RGT y el mantenimiento de redes
Serie N	Mantenimiento: circuitos internacionales para transmisiones radiofónicas y de televisión
Serie O	Especificaciones de los aparatos de medida
Serie P	Calidad de la transmisión telefónica, instalaciones telefónicas y redes de líneas locales
Serie Q	Conmutación y señalización, y mediciones y pruebas asociadas
Serie R	Transmisión telegráfica
Serie S	Equipos terminales para servicios de telegrafía
Serie T	Terminales para servicios de telemática
Serie U	Conmutación telegráfica
Serie V	Comunicación de datos por la red telefónica
Serie X	Redes de datos, comunicaciones de sistemas abiertos y seguridad
Serie Y	Infraestructura mundial de la información, aspectos del protocolo Internet, redes de próxima generación, Internet de las cosas y ciudades inteligentes
Serie Z	Lenguajes y aspectos generales de soporte lógico para sistemas de telecomunicación